

Part 1 - Gmail Add-on: Malicious Email Scorer

1. Product Overview & Vision

A Gmail Add-on that analyzes emails in real-time to deliver a Maliciousness Score, a clear verdict, and Explainable Security insights.

Advanced phishing often bypasses standard filters. Moving beyond black-box blocking, our vision promotes Explainable Security—explaining *why* an email is dangerous to empower secure decisions and build user awareness directly inside Gmail.

2. User Persona & Focus

Target User: Everyday individuals and freelancers managing high-volume inboxes who lack cybersecurity expertise and need quick, intuitive guidance to avoid phishing scams.

Focus Strategy (Trade-off): We chose individual users for our MVP to bypass complex enterprise compliance and IT integrations, allowing us to focus entirely on analysis accuracy and transparent, educational UX.

3. Product Scope

To precisely address the assignment requirements and establish a complete user experience, the following core features were selected for the initial version:

Core Features (MVP)

Feature	Description
Gmail Add-on (Core Requirement)	Native presence within the workspace. Prevents context switching and enables a seamless experience right upon opening an email.
Maliciousness Score (Core Requirement)	Distills the analysis algorithm into a quick visual/numerical metric, enabling rapid risk assessment at a glance.
Clear Verdict (Core Requirement)	Translates the score into a definitive, action-oriented bottom line (e.g., "Safe", "Suspicious", "Malicious").
Explanation (Core Requirement) & Transparency	Highlights 2-3 "red flags" in plain language (e.g., "Sender address mismatch") to build trust and educate the user.
Context-Aware Alerts	Provides concrete guidance based on content. For example, if a suspicious file is detected, a prominent warning reads: "Do not open the attached file."
Data & Text Classification Engine	Analyzes data by verifying sender identity and scanning links, combined with text analysis to detect manipulation and urgency tactics.
Quick Actions	Adding direct action buttons in the add-on (such as "Delete" or "Report") to enable rapid threat resolution straight from the interface.

Roadmap - Future Work & V2.0

Future Feature	Description
LLM Integration for Advanced Analysis	Deep analysis of complex contexts and linguistic nuances. Before implementation, a comprehensive security and privacy review is required. In the MVP, we used a lightweight, fast engine to minimize latency and operational costs.
Human-in-the-Loop & ML Feedback Mechanism	Allowing user intervention to update the system and training the model in the background using feedback data. These capabilities were excluded from the MVP to simplify the initial release.
Quick Actions	Direct action buttons (e.g., "Block Sender") to enable rapid threat resolution straight from the interface.
Deep Attachment Scanning	An advanced layer of protection against malware. Omitted from the MVP to ensure fast response times and prevent loading delays.

4. Email Risk Analysis Approach

I chose to analyze six key areas because phishing emails are usually identified through inconsistencies across multiple layers, rather than by a single indicator. The system combines sender identity, authentication, links, content, attachments, and HTML structure to build an overall risk assessment. Each Signal is only an indication on its own. The final decision is based on the severity and combination of multiple signals, helping detect both technical impersonation and Social Engineering while reducing False Positives.

1. Sender / Identity

Checks sender identity, email address, and domain consistency, including Brand Impersonation, Look-alike domains, and From/Reply-To mismatches.

2. Authentication

Checks SPF, DKIM, and DMARC. Failures are treated as supporting signals rather than standalone proof.

3. Links

Checks whether displayed links match their actual destination and detects raw IPs, URL shorteners, and misleading domains.

4. Content

Detects Social Engineering patterns such as urgency, threats, credential requests, payment requests, or bank detail changes. The MVP uses Rules and Regex.

5. Attachments

6. Inspects Metadata only, without opening or executing files. Checks include double extensions, executables, macro-enabled files, and file-type mismatches.

7. Structure

Analyzes HTML for embedded forms, hidden content, zero-width characters, iframe, and script elements. HTML is treated as untrusted input.

5. Scoring Method

Signals are converted into a 0–100 risk score. Each Signal has a severity-based weight, while each category has a Category Cap to prevent one signal family from dominating the score.

Combo Bonuses are added when multiple strong signals reinforce each other, and a Risk Floor can be applied to a small number of highly suspicious combinations.

Signals → Category Caps → Combo Bonuses → Risk Floor → Final Score → Verdict → Recommendation

The final score determines the Verdict: Low Risk, Suspicious, or High Risk.

Note: With more time, I would refine the weights and combinations, and explore additional signals that could improve detection accuracy.

6. Security Considerations

- **HTTPS only** between the Gmail Add-on and FastAPI.
- **Input validation & sanitization** – validate incoming data and treat all email content, links, HTML, and attachments as untrusted input. Never execute HTML/JS, automatically open links, or run attachments.
- **Data minimization** – send only the information required for analysis.
- **Secret management** – API keys and tokens should be stored outside the source code using environment variables or a secure secret store.
- **Privacy & retention** – email content is used only for analysis and should not be persistently stored. Sensitive email content should also be excluded from logs.
- **External AI services** – if Gemini or Hugging Face are used, send only the minimum required data, redact sensitive information where possible, and use the model only as an additional signal.

Note: With more time, I would expand the security review to areas such as secret management, logging, rate limiting, and service authentication.

7. Design & User Experience

The add-on is designed to support fast decision-making with a clear score, verdict, key risk signals, and recommended action.

Explainability: Users can understand *why* an email was flagged, for example due to a suspicious sender, hidden link, or urgent language.

User Flow: Analysis starts automatically when the add-on opens. Medium- and high-risk emails include Report Phishing, while high-risk emails also include Delete Email.

The add-on uses three risk categories, each with a clear color for fast recognition:

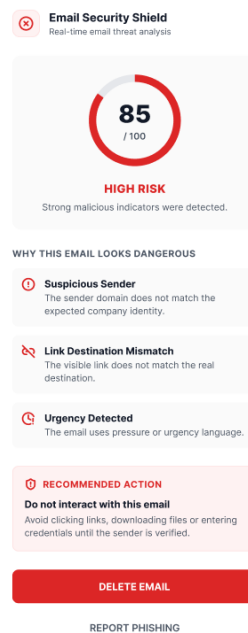
- Low Risk - Green
- Suspicious / Medium Risk - Orange
- High Risk - Red

The user immediately sees the score, classification, key signals, and recommended action.

The full Figma design cannot be implemented exactly because Gmail Add-ons use Google CardService, which limits custom styling compared with HTML/CSS.

Note: With more time, I would further refine the visual design and add a custom wave surfboard logo as part of the product identity.

Design Vision:



8. System Architecture

The system follows a modular client-server architecture, separating the Gmail Add-on from the backend analysis logic.

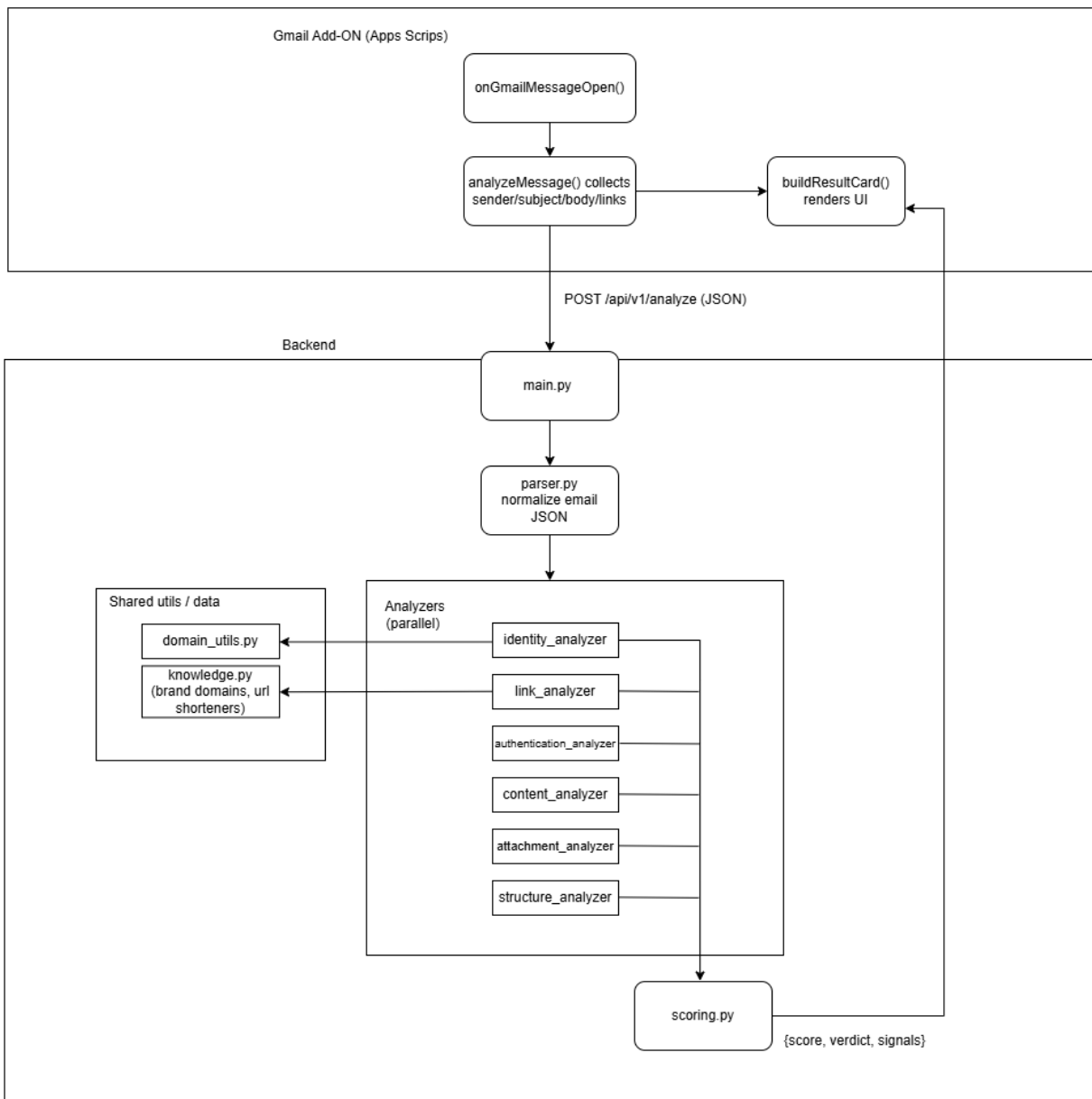
On the client side, the Gmail Add-on is implemented with Google Apps Script. When an email is opened, `onGmailMessageOpen()` triggers `analyzeMessage()`, which collects the sender, subject, body, links, and authentication results and sends them as JSON via HTTPS POST to `/api/v1/analyze`.

On the backend, `main.py` receives the request and `parser.py` normalizes the input. The email is then processed by independent Analyzers for Identity, Links, Authentication, Content, Attachments, and Structure. Shared modules such as `domain_utils.py` and `knowledge.py` support domain handling and static reference data.

Each Analyzer returns explainable Signals, which are combined by `scoring.py` to calculate the final risk score and verdict. The backend returns the result as JSON, and the Add-on renders it using `buildResultCard()`.

The architecture emphasizes separation of concerns, modularity, explainability, and MVP simplicity, making the system easy to test, extend, and debug.

Note: Due to time constraints, the Gmail Add-on frontend is currently kept in a single `Code.gs` file. With more time, I would split it into separate files for parsing, API communication, UI, and user actions.



Part 2 - Product Review

Part A - Product Review

1. Information Security, Permissions, and Report Distribution

- **Gap:** The Visibility and RBAC model is not fully defined. It is unclear whether "Organization level" means every user in the organization can view the report, what happens when sending reports or authenticated links to external parties, and whether warnings exist before sending sensitive security data outside the organization.
- **Importance:** Lack of clarity regarding permissions during distribution may lead to exposing sensitive security data (such as Vulnerabilities and Findings) to unauthorized internal users or external parties.
- **Required Information:** Precise definition of access rules for PDFs and links (including external recipients), view/edit/delete permissions for each visibility level, and restrictions on sharing sensitive information.

2. Custom Dashboard Sync and Ownership

- **Gap:** The operational relationship between a Custom Dashboard and a Report when "Sync board changes to future reports" is enabled or disabled is undefined. Additionally, how boards (Custom Dashboards) are created and edited is completely missing. It is unclear what happens to dependent Reports or Scheduled Workflows when a Dashboard is deleted, who the Owner is, and whether changes made by one user on a shared board can overwrite reports belonging to others.
- **Importance:** Reports are used for management reviews and Compliance. Uncontrolled changes or a lack of understanding regarding board management can alter future reports without users knowing, or break scheduled reports due to deletion.
- **Required Information:** A full specification on board creation and editing, ownership policies, deletion behavior, whether version history or rollback options are required, and whether the sync operates as a snapshot or a dynamic link.

3. Scale and Performance Limitations for Operational Data

- **Gap:** The PRD does not define technical limitations for Operational Data exports (such as maximum row count, allowed CSV file size, expected generation times, and behavior in case of a timeout).
- **Importance:** Enterprise customers may have hundreds of thousands of findings. Unrestricted export will place heavy load on the backend and database, cause timeouts, and impact platform performance.

- **Required Information:** Guidelines from Engineering regarding supported limits per export, generation strategy (synchronous vs. asynchronous), timeout handling, and UX when limits are exceeded.

4. Report Management Across the Lifecycle

- **Gap:** The workflow for managing existing reports on the Reports page (search, view, edit, delete), handling ownership if the creator leaves the organization, and report behavior when the underlying data source is deleted or modified are unclear.
- **Importance:** The reporting feature is built around saved objects. Without a clear solution, reports can become untrustworthy or break without the user understanding why.
- **Required Information:** Precise definition of all CRUD operations on the report object, ownership management, handling dependency changes, and generation history.

Additional Gaps:

- **Saved View and Save as Custom Report:** It is not defined whether a Saved View used as a Scope saves settings as a snapshot or remains linked and updates dynamically, nor does it detail which exact fields are transferred in "Save as Custom Report" (filters, columns, time range, or a combination).
- **Summary Report:** It is unclear what the added value is or what the Summary includes beyond a standard dashboard PDF export (e.g., whether AI or new content is used).
- **Workflow Selectors and Flow:** Technical specification is missing regarding scheduling options, editing, and deleting workflows.
- **Empty States and Failures:** Edge cases are not addressed (what happens when a scope returns zero findings, file generation or download fails, a scheduled delivery fails, or duplicate report names exist).
- **Audit Logging:** Details are missing on exactly what data is stored in the log (whether downloads and generations are also recorded, and who is authorized to view them).
- **Delivery Channels:** The gap between the product vision (support for channels like Slack) and the actual implementation in the current release (email only).

Part B - Test Plan

Guidelines and Test Strategy

- **Testing Scope:** This plan does not drill down to the resolution of every single button click; rather, it outlines the core required test scenarios. These scenarios will be executed multiple times across various environments and configurations to provide broad coverage and validate the overall stability of the feature.
- **Strict Release Gate:** Complete resolution and sign-off on all security and permissions (RBAC) issues is mandatory. The version will not be released without rigorous verification that no data is exposed to unauthorized users.
- **Negative Testing & Error Handling:** Although this area is not fully defined in the requirements and will not serve as a blocker for the current release phase, it will still be incorporated and tested. We will conduct **Negative Testing** evaluating the system under edge cases and error states (e.g., invalid data entry, typos, missing mandatory fields, or empty reports) to close gaps and ensure the system displays clear error messages and does not crash.

Summary Report

Test Area	Short Description	Expected Result	Priority
Create a Report from a Predefined Dashboard	Enter the report details, select each of the available Predefined Dashboards, and complete the full report creation flow	A report can be created successfully from every available Dashboard without errors or missing content	Critical
Scope / Resources	Test several Scope configurations: a single Resource, multiple Resources, and different combinations of Account / Cluster / Namespace, according to what is available in the system	The Preview and PDF include only data that belongs to the selected Scope	Critical
Relative Time Range	Go through all time-range options available in the UI and generate a report for each one	For every selected time range, the data and trends shown in the Preview and PDF match the selected period	High
Preview + Save	For each tested configuration, verify that the Preview is displayed correctly, then save the report	The Preview matches the selected configuration, and the report is saved and appears on the main Reports page with the correct details	Critical
Visibility	Create one report as “Only for me” and another as “Organization level”, then validate access using different users	A personal report is accessible only according to the relevant personal permissions, while an organization-level report is accessible to authorized users in the organization	Critical
Create a Report from a New Custom Dashboard	Create and save a new Custom Dashboard, select it when creating a Summary Report, enter the report details, Scope and Time Range, and generate the report	The new Dashboard is available for selection, the report is successfully generated and saved, and the Preview/PDF displays the selected content and data. The report also appears correctly on the main Reports page	Critical

Limitations:

- **Custom Dashboard creation and editing** - The PRD does not define how a Custom Dashboard is created or edited, what components can be added, or how changes are saved. Therefore, dashboard functionality itself will not be tested; testing will focus on using an existing dashboard as a report source.
- **Predefined Dashboard content** - The expected content of each predefined dashboard is not specified. Testing can confirm that the correct dashboard is selected and exported, but content accuracy requires an additional source of truth.
- **Scope / Resource combinations** - The PRD provides examples such as Account, Cluster and Namespace, but does not define the complete list of supported resource types or combinations.
- **SYNC and Board Creation** - Unspecified, as detailed in Part A.

Operational Data Report

Test Area	Short Description	Expected Result	Priority
Create a report from each supported Module	Complete the report creation flow for every supported Module, including report details and Scope/Filters selection	A report can be created from every supported Module, and the displayed data belongs to the selected Module	Critical
Scope & Filters	Test a single Resource, multiple Resources, Saved View, module-level filters, and combinations of them	The report includes only Findings that match the selected Scope and filters	Critical
Column Selection & Order	Test selecting a subset of columns, all columns, and changing the column order	Only the selected columns are included, in the exact order defined by the user	High
In-app Table & CSV	Verify that the in-app table and the CSV reflect the same selected data, filters, and columns	The content is consistent and accurate between the in-app table and the generated CSV	Critical
Save & Reports Page	Save the report and verify it appears on the main Reports page; then update the report and generate it again	The report appears with the relevant details, and updated settings are saved and reflected in future generations	Critical
Visibility & RBAC	Test “Only for me” and “Organization level” with authorized and unauthorized users	Access to the report and available actions follow the selected Visibility and RBAC permissions	Critical
Edge Cases & Scale	Test 0 Findings, a very large dataset, and report generation/download failure	The system handles these cases clearly and safely, without incorrect data or a partial/corrupted file	High

Limitations:

- **Available Module Filters** - Specific filters per module are undefined. Testing will rely on the current UI, but completeness cannot be fully verified.
- **Scope / Resource Combinations** - An exhaustive list of supported resources and valid combinations is missing, leaving edge cases undefined.
- **Saved View Behavior** - It is unclear whether a Saved View acts as a static snapshot or a dynamically updating live link.
- **CSV / Large Dataset Limits** - System limits for exports (e.g., max rows, file size, timeouts) are undefined, lacking clear pass/fail thresholds.
- **Editing and Failure Handling** - Workflows for editing saved reports and specific error messaging or recovery mechanisms for failures are missing.

Reports Page

Test Area	Short Description	Expected Result	Priority
Saved Reports Display	Create several reports of different types and verify that they appear on the Reports page	Each saved report appears with the relevant details defined in the PRD	Critical
Visibility Across Users	Create a personal report and an organization-level report, then access the page with different users	Each user sees their own personal reports and the organization-level reports they are authorized to access; other users' personal reports are not exposed	Critical
Search & Filters	Test search by name and filtering by Module, Creation Date, Creator, and Workflow	Only reports matching the selected search or filter criteria are displayed	High
Download	Download a report directly from the Reports page	The correct report is downloaded successfully according to its saved configuration	Critical
Workflow Association	Check a report with an associated Workflow and one without a Workflow	A scheduled report displays its associated Workflow; a report without one provides an option to create a Workflow	High
RBAC / Permissions	Access the Reports page with users who have different permissions	Each user can only view and perform actions allowed by their permissions	Critical
On-demand Generation	Manually generate and download a saved report at any time	The correct report is generated successfully using its saved configuration	Critical
Edge Cases	Test an empty Reports page, search with no results, and download/generation failure	A clear state or error message is shown and the page does not display misleading information	Medium

Limitations

- **User Display Rules** - The exact criteria determining which reports populate on the page for each user are undefined
- **Row Metadata** - The specific report details and columns expected to be displayed in each row are not specified
- **Inline Actions** - It is unclear whether viewing, editing, or deleting reports directly from the Reports page is supported or how it functions
- **Lifecycle Workflows** – The complete end-to-end user flows for creating, editing, and deleting report objects are missing
- **Visibility vs RBAC** - The interaction between "Organization-level" visibility and specific RBAC permissions is undefined
- **Failure Handling** - Expected system behavior and error messaging for report generation or download failures are not specified

Visibility Controls

Test Area	Short Description	Expected Result	Priority
Visibility Controls across all report types	Create each report type as both Only for me and Organization level : Summary Report, Operational Data Report, and a report created through Save as Custom Report. Verify visibility using different users	Personal reports are visible only to the creator, while organization-level reports are visible to the users who are expected to have access. The report is displayed accordingly on the Reports page	Critical

- It is unclear whether Organization level means visible to all users in the organization or only to users with relevant RBAC permissions.
- It is not defined which permissions users have on an organization-level report, such as view, download, edit, or delete.
- It is unclear whether visibility can be changed after the report is saved.

Scheduled Delivery via Workflows

Test Area	Short Description	Expected Result	Priority
Scheduled Delivery	Connect a saved report to a Workflow and configure email delivery	The correct report is sent at the scheduled time according to the Workflow settings	Critical
Large File Delivery	Generate a report that exceeds the email attachment size limit	An authenticated download link is sent instead of an attachment	High
Generation / Delivery Failure	Simulate a failure during report generation or email delivery	The failure is handled clearly and is not incorrectly presented as a successful delivery	High

- The spec does not define what Workflow Selectors are or what they control.
- It is unclear whether a Workflow can be edited or deleted after creation.
- It is unclear what happens if a configured recipient is no longer part of the organization at delivery time.
- The available scheduling options and whether multiple recipients can be configured are not specified.

- It is not defined what happens if the report configuration changes between Workflow creation and the scheduled delivery time.

Audit Logs

Test Area	Short Description	Expected Result	Priority
Report Creation	Create a new report (Summary or Operational Data) and verify the action is logged.	A record appears in the audit log indicating the report creation (Create).	High
Report Update	Edit an existing report (e.g., change name, Scope, or visibility settings) and save it.	A record appears in the audit log indicating the report update (Update).	High
Report Deletion	Delete an existing report via the UI.	A record appears in the audit log indicating the report deletion (Delete).	High

- **Location & Access:** The PRD does not describe where the audit logs are located in the system, what the interface looks like, or how users can navigate to them.
- **Record Metadata:** It is undefined what specific data points are captured in each audit log entry (e.g., executing user, timestamp, IP address, report name, and whether "Update" actions specify exactly which fields were changed).
- **Permissions:** It is not defined who has the required permissions to view the audit logs (e.g., whether it is restricted to system administrators or accessible to other roles).

Scheduled Delivery & Large Files

Test Area	Short Description	Expected Result	Priority
Standard Delivery	Trigger a scheduled delivery via Workflows for a report within normal size limits.	The report is successfully delivered directly as an email attachment.	Critical
Large File Delivery	Trigger a scheduled delivery for a report exceeding the size limits (e.g., over 500 MB/rows/pages).	The platform detects the large size and sends an email with an authenticated download link instead of attaching the file directly.	High
Link Authentication	Attempt to download a large report using the provided email link with authenticated and unauthenticated sessions.	The system strictly requires user authentication before allowing the report download to proceed.	Critical

- **Exact Size Thresholds** - The PRD mentions "destination's size limits" but does not specify exact metrics. It is unclear if a limit like "500" refers to megabytes, maximum row count for CSVs, or page limits for PDFs.
- **Link Expiration** - It is completely undefined how long the authenticated download link remains valid before expiring.

- **Destination Types** - The overview mentions delivering through "channels and integrations they already use," but the release scope only explicitly mentions email delivery. It is unclear if integrations like Slack or Jira are supported in this specific release.
- **Email Formatting** - The template, subject line, sender details, and handling of multiple recipients for the delivery emails are not specified.

Part 3 - BI & Monitoring

1. Adoption & Usage

1. Feature Weekly Active Users

- **Description:** The number of unique users who performed an action (creating, editing, downloading, or scheduling a report) within the last week.
- **Value:** Indicates whether the feature has become a daily workflow tool or if it was just a one-time novelty.
- **Metric:** Count of unique users who interacted with the feature, with the ability to filter the data by organization and by specific teams.

2. Report Creation Funnel

- **Description:** The percentage of users who started creating a report and actually saved or exported it, identifying the exact step where they dropped off the process.
- **Value:** Identifies friction in the user experience. If many users abandon the process at a specific screen, we know there is a usability issue that requires fixing.
- **Metric:** The number of users who completed the flow divided by the number of users who started it, plus tracking the transition rates from one screen to the next.

3. Automation vs. Manual Action Ratio

- **Description:** The ratio between scheduled reports (sent automatically) and reports generated or downloaded manually by the user.
- **Value:** The real value in Enterprise is reducing manual work. If everyone is only downloading manually, we missed the goal of automation.
- **Metric:** The number of reports configured with a recurring schedule out of the total reports generated in the system.

4. Report Types, Scope, and Origins (Use Cases)

- **Description:** The distribution of usage by format (CSV vs. PDF), report scope (personal vs. general), and the generation origin (e.g., a report saved in advance under "Saved," a direct CSV download from the screen, or generated from the general reports system).
- **Value:** Helps determine where to focus future development. If the vast majority of users download operational CSVs directly from the screen, we need to improve data retrieval performance rather than invest in chart design.
- **Metric:** Calculating the percentage of each category (format, scope, and origin) out of the total reports generated.

2. Quality & Reliability (Operational Health)

1. Generation Success Rate

- **Description:** The percentage of reports successfully generated and sent or downloaded without errors.
- **Value:** System reliability. Compliance and operational reports are critical for customers, and failures will cause a loss of trust.
- **Metric:** The number of successfully generated reports divided by the total number of report generation attempts.

2. Generation Latency

- **Description:** The time it takes for the system to generate a report, from the moment the request is sent until the file is ready for the user.
- **Value:** Data-heavy reports can overload the system or fail due to excessively long wait times.
- **Metric:** Timing the generation process in seconds from start to finish, highlighting the data of the reports that take the longest time to be ready.

3. Alerting Strategy

Immediate Alerts (On-call):

- **Success Rate Drop:** An automatic alert if the success rate drops below 95% within a 30-minute window.
- **Processing Time Spike (Latency):** An alert if report generation starts taking significantly longer than usual and crosses the maximum allowed time threshold. This indicates a heavy system load that could lead to service crashes.
- **Outbound Delivery Failure:** An alert if an unusual percentage of scheduled reports fail during the email delivery stage.

Routine Review: On a weekly or monthly basis, an ongoing review (without active alerts) will track all the adoption, usage, and health metrics mentioned above (feature adoption trends, funnel drop-offs, format distribution, etc.).

4. Missing Data to Request from Engineering (Missing Telemetry)

To build this dashboard, we must ensure the development team logs the following data:

1. **Detailed Error Codes:** Clear categorization of failure reasons (e.g., data overload, lack of permissions, email delivery failure) rather than a generic "general error."

2. **UI Event Tracking:** Logging clicks on every screen to accurately measure the creation funnel.
3. **"Actual Download" Identification:** A log that distinguishes between a report that was merely saved in the system and a report the user actually clicked on and downloaded to their computer.

Bonus - Future Product Opportunities

Beyond the current scope, I would consider several product improvements:

- **Custom Date Range:** In addition to relative time ranges, allow users to select exact start and end dates. This is useful for audits, incidents, quarterly reviews, and comparing specific periods.
- **Report Comparison & Progress Tracking:** Allow users to compare the current report with a previous report and see what changed - new findings, resolved findings, and remaining issues. This would turn reports from static snapshots into a way to measure remediation progress.
- **Ownership & Team Assignment:** Add fields such as Status, Owner, Team, and Responsibility Area, with the ability to filter reports/findings by team or owner. This would make it clearer who is responsible for each issue.
- **Collaborative Reports:** Instead of reports being mainly exported as PDF/CSV, allow users to open a live report inside the platform, collaborate, add comments or status updates, and keep it continuously updated.
- **Ticketing Integration:** Findings could be converted directly into Jira tickets, assigned to the relevant team, tracked from Open → In Progress → Resolved, and reflected back in the report.
- **More Granular Sharing:** Today visibility appears to support only “Only for me” or “Organization level.” I would consider sharing by specific teams, roles, or users, especially for organizations where security information should only be exposed to the relevant stakeholders.